

Auditoria final independente - App Android Logística Casa do Campo v2.7.0

Data da execução: 25/08/2026

Escopo: backend, SQLite, autenticação/autorização do motorista, PWA/WebView, modo offline, migrações, Gradle/APK e preparação Cloudflare.

Método: revisão do código e das alterações locais, testes automatizados, gates em bancos temporários, leitura do banco configurado e fluxo E2E em navegador controlado. Nenhum teste funcional escreveu no banco operacional.

Conclusão

O repositório está consistente e o APK **debug** v2.7.0 foi gerado com sucesso. Não foi encontrada falha pendente nos itens executáveis nesta máquina. A liberação em aparelho real e a publicação externa ainda dependem dos testes marcados como **NÃO EXECUTADO**: câmera/QR/assinatura com rotação em hardware Android, instalação/atualização no aparelho e túnel HTTPS/DNS Cloudflare real.

Artefato: output/apk/Logistica_Casa_do_Campo-v2.7.0-debug.apk

Pacote: br.com.casadocampo.logistica

Versão: versionCode=27, versionName=2.7.0

Tamanho: 6.943.512 bytes

SHA-256: 26C6FF5C0DD55C27EEA63784E6EE20E4932E6A7A4B4EE6F78243F8194B15661C

Resultado factual

Área	Resultado	Evidência
Versão Android/PWA v2.7.0	PASSOU	aapt dump badging: versionCode 27, versionName 2.7.0, minSdk 21, target/compileSdk 33.
Fonte Android canônica	PASSOU	tools/build_android_apk.py; fonte duplicada fora de app/ removida.
Gradle limpo	PASSOU	clean lintDebug testDebugUnitTest assembleDebug: BUILD SUCCESSFUL; 40 tarefas executadas.
Testes unitários Android	NÃO EXECUTADO	O módulo não contém fontes de teste Android; Gradle informou testDebugUnitTest NO-SOURCE.
Lint Android	PASSOU	Zero erros; sete avisos não bloqueantes: atributos condicionais à API, três dependências com versões mais novas disponíveis e dois avisos do ícone legado.
Manifesto/APK	PASSOU	Pacote, versão e permissões INTERNET/CAMERA/NETWORK conferidos dentro do APK com aapt.
Suíte Python completa	PASSOU	68 testes em 29,609 s, resultado OK.
Sintaxe Python/JavaScript	PASSOU	compileall, node --check driver.js e node --check sw.js.
Banco configurado - integridade	PASSOU	integrity_check=ok, foreign_key_check=0, referências órfãs=0.
Migração atual	PASSOU	Banco configurado em 0004_driver_app_security_integrity; migração limpa e migração de banco legado testadas.
Credenciais de motoristas	PASSOU	8 motoristas; hashes inválidos=0; PIN em texto puro=0; hashes de sessão inválidos=0.
Login e primeiro acesso	PASSOU	Senha padrão exige troca; senha mínima de oito caracteres; token expirado/adulterado negado; logout revoga somente hash.
Limite de tentativas de login	PASSOU	Teste automatizado e gate de caos confirmaram bloqueio HTTP 429.
Isolamento motorista A/B	PASSOU	Rotas, detalhe, início e finalização de outro motorista foram negados.
Entrega	PASSOU	Commit atômico, idempotência, um comprovante, histórico do pedido e fechamento automático da carga.
Problema de entrega	PASSOU	Tipo/observação persistidos; histórico criado; carga finalizada como Com problema quando aplicável.
Rollback em erro 500	PASSOU	Falha forçada na tabela de comprovantes não deixou estado parcial nem histórico indevido.
Clique duplo/reenvio	PASSOU	Bloqueio na interface mais chave idempotente no servidor; somente uma operação persistida.
Cliente desconectado após commit	PASSOU	Operação permaneceu completed, um comprovante e nenhuma falsa segunda resposta/falha transacional.
Imagens/comprovantes	PASSOU	JPEG/PNG/WebP validados por conteúdo; assinatura somente PNG; base64 inválido e payload excessivo recusados.
Foto no PWA	PASSOU	Seletor real de arquivo, compressão/preview e remoção validados no navegador; imagem 1600×1447 reduzida para cerca de 55 KB.
Câmera nativa/QR em aparelho	NÃO EXECUTADO	Permissão e fluxo compilados; requer aparelho Android físico para aceitar/negar/cancelar e validar câmera/QR.
Assinatura em tela cheia	PASSOU	Abertura, fechamento, botões e ocupação da tela verificados visualmente em 1280×720.
Traço, limpar e rotação da assinatura em aparelho	NÃO EXECUTADO	Exige gesto e mudança real de orientação no Android físico.
Modo offline - persistência	PASSOU	Rotas/detalhes recuperados do IndexedDB após reinício sem servidor; quatro operações reenviadas com a mesma chave.
Fechamento durante sincronização	PASSOU	Registro syncing recuperado para pending; replay sem duplicidade após servidor lento de 5 s.
Fila por motorista	PASSOU	Registros têm proprietário e contadores/sincronização são filtrados pelo motorista autenticado.
Erro permanente e retry	PASSOU	Falhas permanentes ficam em failed; retry automático limitado a erros transitórios; retry manual disponível.
Cache/service worker	PASSOU	Cache network-first; escrita no cache aguardada dentro do ciclo da resposta; snapshot offline em IndexedDB.
Links de mapa	PASSOU	Somente HTTP/HTTPS; endereço vazio usa busca do Google Maps, sem navegar para a origem local.
CSP do PWA	PASSOU	Scripts inline/eval proibidos nas rotas do app do motorista.

Área	Resultado	Evidência
Gates administrativos	PASSOU	Auditoria final 30/30; caos 35/35; estado/ciclo 25/25; seleção/UX 20/20; smoke operacional sem falhas.
Proxy/Host/forçar senha	PASSOU	Página, redirecionamento para troca obrigatória e submissão validados em servidor temporário.
Scripts Cloudflare locais	PASSOU	PowerShell sem erros de parse; contrato exato do healthcheck presente no PowerShell e BAT.
Túnel/DNS/HTTPS Cloudflare real	NÃO EXECUTADO	cloudflared não está instalado e não foram fornecidos domínio, conta ou credencial.
Certificado público e acesso por rede móvel	NÃO EXECUTADO	Depende do túnel e DNS reais.
Instalação/atualização em aparelho Android	NÃO EXECUTADO	APK debug gerado, mas não havia aparelho físico conectado.
APK release assinado	NÃO EXECUTADO	Foi solicitado/gerado APK debug; keystore de produção não foi fornecido.

Gates executados

- python -m unittest discover -s tests: 68/68.
- python tools/final_audit_check2.py: 30/30.
- python tools/extreme_chaos_audit.py: 35/35, incluindo 280 gravações concorrentes e 40 leituras concorrentes.
- python tools/zero_state_check.py: 25/25.
- python tools/ux_selection_audit.py: 20/20.
- python tools/stress_smoke.py: todos os cenários listados passaram.
- python tools/force_password_proxy_host_audit.py: 3/3.
- python tools/test_app_release.py: 14/14 testes atuais da API do motorista.
- python tools/db_integrity_audit.py e python tools/driver_db_readonly_audit.py: sem inconsistências.
- gradlew clean lintDebug testDebugUnitTest assembleDebug: sucesso.
- E2E do app: login errado, primeiro acesso, início de carga, mapa, foto, entrega, problema, fila offline, reinício offline, reconexão, servidor lento e interrupção durante sincronização.

O gate `e2e_new_order_playwright.cjs` não foi repetido em shell. A auditoria visual desta rodada foi executada pelo navegador controlado, e o fluxo administrativo equivalente foi coberto pelos gates HTTP temporários.

Bugs encontrados e corrigidos nesta auditoria

1. Testes de ERP herdavam `.env` real e tentavam acessar Oracle/cache. Os testes agora limpam/restauram toda configuração ERP e o leitor global.
2. Dois testes escreviam no banco operacional. Ambos passaram a usar SQLite temporário e restauração garantida dos globais.
3. API aceitava base64 arbitrário como imagem. Agora valida magic bytes, tipo real e limite antes da transação.
4. Exclusão de comprovante usava somente `order_id`. Agora usa a chave composta `route_id + order_id`.
5. Senha do motorista podia ter um caractere e não havia rate limit. Agora o mínimo é oito e há bloqueio configurável por IP+identidade.
6. Entregas/problemas do app não criavam `order_history`. Agora o histórico é gravado na mesma transação.
7. Healthcheck era fácil de imitar. Backend, Android e scripts Cloudflare exigem serviço e versão exatos.
8. CSP do PWA permitia script inline/eval. As rotas do motorista receberam política restrita.
9. Operação offline podia ficar eternamente em `syncing` após fechamento. Agora é recuperada e reenviada com a mesma chave idempotente.
10. Fila permitia sincronizações concorrentes, clique duplo, duplicidade por parada e mistura entre motoristas. Foram adicionados locks, deduplicação e proprietário.
11. Erros permanentes eram tentados automaticamente para sempre. A classificação de retry foi separada e há retry manual.

12. Rotas/detalhes desapareciam após reinício offline. Foram adicionados snapshots IndexedDB por motorista.
13. O service worker iniciava escrita no cache fora do ciclo da resposta. Agora a escrita é aguardada corretamente.
14. Problemas não contavam como parada concluída no progresso, e links de mapa vazios abriam a raiz local. Ambos corrigidos.
15. Android não solicitava câmera no seletor de comprovante, o FileProvider não cobria fallback interno e arquivos temporários vazavam. Fluxos e limpeza corrigidos.
16. WebView aceitava caminhos internos excessivos, DNS de hostname HTTP e healthcheck por texto. Allowlist, origem local e JSON exato foram endurecidos.
17. Dados do WebView não tinham regras modernas explícitas contra backup/transferência. `data_extraction_rules.xml` foi adicionado.
18. Gates deixavam diretórios e backups temporários. Limpeza e restauração do backup criado pelo próprio teste foram adicionadas.
19. Desconexão depois do commit era registrada como falha transacional e provocava segunda resposta. Exceções de transporte agora são tratadas separadamente e há regressão automatizada.
20. Scripts Cloudflare validavam apenas `ok=true`. Agora rejeitam origem pública/local que não seja exatamente este sistema e esta versão da API.

Principais arquivos alterados

- Backend/API: `app.py`, `app_core/domains/driver_api_dispatch.py`, `app_core/services/driver_security.py`, `app_core/sqlalchemy_models.py`.
- Banco/migração: `migrations/env.py`, `migrations/versions/0004_driver_app_security_integrity.py`.
- PWA: `static/driver_app/index.html`, `static/driver_app/driver.js`, `static/driver_app/sw.js`.
- Android: `android_app_project/app/src/main/AndroidManifest.xml`, `MainActivity.kt`, `res/xml/file_paths.xml`, `res/xml/data_extraction_rules.xml`, `Gradle/wrapper/proguard`.
- Cloudflare: `tools/setup_cloudflared_named_tunnel.ps1`, `tools/iniciar_tunnel_cloudflared.bat`, `tools/check_driver_public_endpoint.ps1`, `deploy/cloudflared/config.example.yml`.
- Testes: `tests/test_driver_api.py`, `tests/test_driver_migrations.py`, `tests/test_driver_pwa_contract.py`, testes ERP/HTTP/relatório e gates em `tools/`.
- Auditoria reproduzível: `tools/driver_app_audit_server.py`, `tools/driver_db_readonly_audit.py`.

Pendências externas obrigatórias antes de produção

1. Instalar o APK em pelo menos um aparelho Android 8-14 e executar câmera, negar permissão, cancelar seletor, QR, galeria, assinatura com traço/limpar e rotações retrato/paisagem.
2. Criar ou fornecer o keystore para gerar APK/AAB **release assinado**; o artefato atual é debug.
3. Instalar `cloudflared`, configurar domínio/túnel nomeado e executar `tools/check_driver_public_endpoint.ps1` pela internet e por rede móvel.
4. Confirmar atualização sobre a versão instalada preservando sessão/fila IndexedDB e repetir o teste de fechamento durante sincronização no aparelho.

Sem essas quatro verificações externas, não é tecnicamente correto afirmar que a implantação física e pública está 100% concluída, embora todos os itens reproduzíveis no repositório tenham passado.